

DOCUMENTATION TECHNIQUE — API REST

CYNA Security Platform

Documentation API REST — Collection Postman v2.1

BC3 — CPI Bachelor DEV Full Stack 2025-2026

AUTEUR

Omar AKAKBA (Back-End)

SPÉCIALITÉ

DEV Full Stack

DATE

Juillet 2026

VERSION

1.0

BASE URL (LOCAL)

<http://localhost:8888/cyna/api>

BASE URL (PROD)

<https://omar05.alwaysdata.net/cyna/api>

École : INGETIS / SUP DE VINCI — Promotion 2025-2026

Vue d'ensemble de l'API

L'API REST de CYNA expose des endpoints JSON permettant l'accès programmatique au catalogue produits, aux catégories et aux commandes. L'API est construite en **PHP natif (sans framework)** et respecte les conventions REST standard.

3

Endpoints

12

Requêtes documentées

JSON

Format de réponse

Base URL

```
Local (MAMP) : http://localhost:8888/cyna/api
Production : https://omar05.alwaysdata.net/cyna/api
```

Format des réponses

Toutes les réponses sont au format **JSON UTF-8** avec l'en-tête `Content-Type: application/json`. Les réponses d'erreur incluent un champ `error` et un champ `code` HTTP.

Collection Postman : Le fichier `docs/postman_collection.json` peut être importé directement dans Postman ou Bruno pour tester tous les endpoints avec les requêtes préconfigurées.

Authentification

HTTP Basic Authentication

Les endpoints protégés (`/api/orders.php`) nécessitent une authentification **HTTP Basic Auth** :

- **Username** : adresse e-mail du compte CYNA
- **Password** : mot de passe du compte (en clair via HTTPS)

En-tête HTTP : `Authorization: Basic <base64(email:password)>`

Codes de statut HTTP

Code	Signification	Contexte
200 OK	Succès	Données retournées normalement
401 Unauthorized	Authentification requise	Header Authorization absent ou invalide
404 Not Found	Ressource introuvable	ID produit, catégorie ou commande inexistant
500 Internal Server Error	Erreur serveur	Erreur BDD ou exception PHP non gérée

1 — Produits

Public

Endpoint : `/api/products.php` — Accès public, aucune authentification requise.

GET

Lister tous les produits

GET `{{base_url}}/products.php`

Retourne la liste complète des produits disponibles à la vente, avec leur catégorie associée.

✓ 200 OK

```
{
  "count": 6,
  "data": [
    {
      "id": 1,
      "name": "EDR Pro",
      "description": "Protection endpoint avancée...",
      "price": "9.99",
      "duration_months": 1,
      "category_id": 1,
      "category_name": "EDR",
      "image": "/cyna/assets/uploads/products/edr-pro.jpg",
      "available": 1
    },
    ...
  ]
}
```

GET Obtenir un produit par ID

```
GET {{base_url}}/products.php?id=1
```

Paramètres de requête

Paramètre	Type	Requis	Description
id	integer	Requis	Identifiant unique du produit

✓ 200 OK — Produit trouvé

```
{
  "id": 1,
  "name": "EDR Pro",
  "description": "Protection endpoint avancée avec détection comportementale...",
  "price": "9.99",
  "duration_months": 1,
  "category_name": "EDR",
  "available": 1
}
```

✗ 404 Not Found — Produit inexistant

```
{ "error": "Produit introuvable", "code": 404 }
```

GET Filtrer par catégorie

```
GET {{base_url}}/products.php?category_id=1
```

Paramètres de requête

Paramètre	Type	Requis	Description
category_id	integer	Requis	ID de la catégorie à filtrer

Retourne uniquement les produits disponibles appartenant à la catégorie spécifiée.

GET Rechercher un produit

```
GET {{base_url}}/products.php?search=edr
```

Paramètres de requête

Paramètre	Type	Requis	Description
<code>search</code>	string	<i>Requis</i>	Mot-clé à chercher dans le nom et la description

Recherche full-text dans le champ `name` et `description` des produits (`LIKE %keyword%` via requête préparée PDO).

2 — Catégories

Public

Endpoint : `/api/categories.php` — Accès public, aucune authentication requise.

GET Lister toutes les catégories**GET** `{{base_url}}/categories.php`

Retourne toutes les catégories avec le nombre de produits disponibles associés.

✓ 200 OK

```
{
  "count": 3,
  "data": [
    {
      "id": 1,
      "name": "EDR",
      "description": "Endpoint Detection & Response",
      "nb_products": 2
    },
    {
      "id": 2,
      "name": "SOC Managé",
      "description": "Centre opérations sécurité managé",
      "nb_products": 2
    },
    {
      "id": 3,
      "name": "VPN",
      "description": "Réseau privé virtuel d'entreprise",
      "nb_products": 2
    }
  ]
}
```

GET Obtenir une catégorie avec ses produits**GET** `{{base_url}}/categories.php?id=1`

Paramètres de requête

Paramètre	Type	Requis	Description
<code>id</code>	integer	<i>Requis</i>	Identifiant unique de la catégorie

✓ 200 OK

```
{
  "id": 1,
  "name": "EDR",
  "description": "Endpoint Detection & Response",
  "products": [
    { "id": 1, "name": "EDR Pro", "price": "9.99", "duration_months": 1 },
    { "id": 2, "name": "EDR Enterprise", "price": "29.99", "duration_months": 12 }
  ]
}
```

✗ 404 Not Found

```
{ "error": "Catégorie introuvable", "code": 404 }
```

3 — Commandes

Authentifié

Endpoint : `/api/orders.php` — Authentification **HTTP Basic Auth** obligatoire.

⚠ **Sécurité** : Les identifiants sont transmis en Base64 dans l'en-tête HTTP `Authorization`. En production, l'API doit être servie via **HTTPS** pour chiffrer la transmission. Sur Alwaysdata, HTTPS est activé par défaut.

GET

Auth

Lister mes commandes

GET `{{base_url}}/orders.php`

En-têtes requis

En-tête	Valeur	Description
Authorization	Basic <base64>	Credentials utilisateur (email:password encodé en Base64)

Retourne uniquement les commandes de l'utilisateur authentifié. Un utilisateur ne peut pas voir les commandes d'un autre.

 **200 OK**

```
{
  "count": 2,
  "data": [
    {
      "id": 1,
      "reference": "CMD-2026-001",
      "status": "paid",
      "total": "39.98",
      "created_at": "2026-06-01 14:23:05",
      "items": [
        { "product_name": "EDR Pro", "quantity": 1, "unit_price": "9.99" },
        { "product_name": "VPN Enterprise", "quantity": 1, "unit_price": "29.99" }
      ]
    }
  ]
}
```

 **401 Unauthorized — Sans authentication**

```
{ "error": "Authentication requise", "code": 401 }
```


GET

Auth

Détail d'une commande

```
GET {{base_url}}/orders.php?id=1
```

Paramètres de requête

Paramètre	Type	Requis	Description
<code>id</code>	integer	<i>Requis</i>	ID de la commande

Retourne le détail complet d'une commande (lignes, prix unitaires, durées, référence Stripe). Seules les commandes appartenant à l'utilisateur connecté sont accessibles.

✗ 404 — Commande inexistante ou appartenant à un autre utilisateur

```
{ "error": "Commande introuvable", "code": 404 }
```

4 — Importer dans Postman / Bruno

Postman

1. Ouvrir Postman
2. Cliquer sur **Import** (bouton en haut à gauche)
3. Sélectionner **File** → choisir `docs/postman_collection.json`
4. La collection *CYNA API — Collection complète* apparaît dans le panneau de gauche
5. Configurer la variable `base_url` dans l'environnement (défaut : `http://localhost:8888/cyna/api`)
6. Pour les commandes (auth) : configurer `email` et `password` dans l'onglet Authorization de la requête

Bruno (alternative open-source)

1. Télécharger Bruno depuis `usebruno.com`
2. Ouvrir une collection → sélectionner *Import* → *Postman Collection*
3. Choisir `docs/postman_collection.json`

Test rapide via curl :

```
curl -s http://localhost:8888/cyna/api/products.php | python3 -m json.tool  
curl -u "client@test.fr:Admin1234!" http://localhost:8888/cyna/api/orders.php
```

5 — Sécurité de l'API

Mesure	Implémentation	Fichier
Requêtes préparées PDO	Tous les paramètres SQL sont passés via <code>execute()</code> — prévient l'injection SQL	<code>api/products.php</code>
Échappement des sorties	Toutes les chaînes de texte passent par <code>htmlspecialchars()</code> avant sérialisation JSON	<code>includes/security.php</code>
Authentification Basic Auth	Vérification email + <code>password_verify()</code> — hash bcrypt cost=12	<code>api/orders.php</code>
Contrôle d'accès	Un utilisateur ne peut consulter que ses propres commandes (clause <code>WHERE user_id = ?</code>)	<code>api/orders.php</code>
En-têtes de sécurité	<code>X-Content-Type-Options: nosniff</code> , <code>X-Frame-Options: DENY</code>	<code>api/*.php</code>

CYNA Security Platform — Documentation API REST — Juillet 2026
Auteur : Omar AKAKBA — BC3 CPI Bachelor DEV Full Stack — INGETIS / SUP DE VINCI